

Тема 5. Списки контроля доступа ACL: стандартные ACL и защита управл

Цель лекции

Понимать, где ACL применяются и почему сама созданная ACL еще не фильтрует трафик

Объяснять порядок обработки правил, ACE и implicit deny

Настраивать стандартные ACL по Source IPv4 Address

Защищать VTY-линии SSH через access-class и проверять счетчики совпадений

Учебные вопросы

1. Фильтрация трафика и безопасность на L3/L4 с помощью ACL
2. Последовательная обработка правил сверху вниз
3. Неявный запрет `implicit deny`
4. Стандартные ACL по Source IP и расширенные ACL
5. Размещение стандартных ACL ближе к получателю, расширенных — ближе к источнику

1. ACL описывает, какой трафик разрешить или запретить

ACL (Access Control List) — список правил фильтрации трафика на сетевом устройстве

ACL может ограничивать доступ между подсетями, к серверам или к управлению устройствами

ACL как семейство механизмов может проверять параметры L3 и L4

Стандартная IPv4 ACL проверяет только Source IPv4 Address

Расширенная ACL дополнительно проверяет Destination IP, протокол и транспортные порты

ACL не заменяет полноценный firewall

ACL является статическим списком правил без глубокого анализа приложений

Она не отслеживает состояние соединения как stateful firewall

ACL хорошо подходит для базового разграничения и защиты административного доступа

Для периметра предприятия обычно используют firewall, NAT, VPN и журналирование

На сетевых устройствах ACL должна быть простой, понятной и документированной

Схема: ACL как фильтр на интерфейсе маршрутизатора

ACL не действует сама по себе. Она начинает фильтровать трафик, только когда применяется к интерфейсу с помощью `ip access-group`.



КЛЮЧЕВЫЕ ВЫВОДЫ

ACL — это фильтр. Он применяет правила к проходящим пакетам.

Где применили — там и фильтрует. Без `ip access-group` ACL не влияет на трафик.

Первое совпадение решает. ACL читается сверху вниз, далее не проверяется.

Implicit deny в конце. Всё, что не разрешено, будет отброшено.

2. ACL читается сверху вниз до первого совпадения

ACL — весь список правил

ACE (Access Control Entry) — отдельная строка ACL с permit или deny

Маршрутизатор проверяет пакет по первой ACE сверху
вниз

Если пакет совпал с ACE, выполняется permit или deny
и проверка заканчивается

Нижние строки уже не анализируются после первого
совпадения

Более конкретные разрешения обычно ставят выше
общих запретов

Пример ошибки порядка правил

Строка `deny 192.168.10.0 0.0.0.255` запрещает всю пользовательскую VLAN

Пакет от 192.168.10.50 совпадает с этим `deny` и сразу отбрасывается

Если ниже написать `permit host 192.168.10.50`, это разрешение уже никогда не сработает

Правильнее сначала разрешить исключение, затем запретить остальную подсеть

Счетчики `show access-lists` помогают понять, какие ACE реально совпадают

3. В конце любой ACL есть `implicit deny`

`Implicit deny` — неявное правило `deny any` в конце стандартной IPv4 ACL

Для расширенной IPv4 ACL логический вариант выглядит как `deny ip any any`

Оно не отображается как обычная строка, но применяется после последней ACE

Если не добавить `permit` для нужного трафика, он будет отброшен

Перед применением ACL нужно заранее определить, что именно должно остаться разрешенным

ACL начинает фильтровать только после применения

Можно создать ACL, и она будет просто храниться в конфигурации

Без access-class на VTY или ip access-group на интерфейсе она не влияет на трафик

Implicit deny действует только там, где ACL реально применена

Пример: ACL MGMT_ONLY без access-class MGMT_ONLY in не защитит SSH

Пример: ACL BLOCK_VLAN40 без ip access-group не отфильтрует интерфейсный трафик

deny any log нужен для диагностики, но не всегда обязателен

Явная строка deny any log показывает запрещенные попытки в журнале

Implicit deny уже существует даже без явной строки deny

Опция log создает сообщения при совпадениях

На загруженном интерфейсе deny any log может увеличить нагрузку на CPU и Syslog

Для VTY-трафика объем обычно небольшой, поэтому log часто приемлем в учебной сети

Диаграмма: порядок обработки ACL и implicit deny



ACL проверяется сверху вниз. Как только найдено первое совпадение, выполняется действие **permit** или **deny**, и дальнейшие строки уже не анализируются.

Пакеты на входе

Пакет А
Источник:
192.168.10.50

Совпадает со строкой 10
→ **PERMIT**

Пакет В
Источник:
192.168.10.77

Не совпадает со строкой 10,
совпадает со строкой 20
→ **DENY**

Пакет С
Источник:
192.168.30.10

Нет совпадений ни с одной
явной строкой → **implicit deny**
→ **DENY**

Пример ACL		
10	permit host 192.168.10.50	✓ PERMIT
20	deny 192.168.10.0 0.0.0.255	✗ DENY
30	permit 192.168.20.0 0.0.0.255	✓ PERMIT
...		
implicit deny any		✗ DENY

неявное правило в конце



Что важно понять

- 1 ACL = список правил, ACE = отдельная строка
- 2 Проверка идет только **сверху вниз**
- 3 Решает **первое совпадение**
- 4 Если совпадений нет — срабатывает **implicit deny**



Типичная
ошибка

10	deny 192.168.10.0 0.0.0.255
20	permit host 192.168.10.50

✗ Разрешение ниже уже не сработает, потому что пакет будет отброшен раньше.



Исключения размещают выше общих запретов.

Легенда

- ✓ = **permit** / трафик разрешен
- ✗ = **deny** / трафик запрещен
- - - - - → = переход к следующей строке

Wildcard mask показывает совпадающие и игнорируемые биты

Wildcard mask показывает, какие биты адреса сравниваются, а какие игнорируются

0 в wildcard означает строго сравнивать бит

1 в wildcard означает игнорировать бит

Для обычных непрерывных масок wildcard можно считать вычитанием из 255

Сеть 192.168.10.0/24 записывается как 192.168.10.0
0.0.0.255

Host, сеть и any имеют эквивалентные записи

permit 192.168.99.50 0.0.0.0 разрешает один конкретный адрес

permit host 192.168.99.50 делает то же самое короче

permit 192.168.99.0 0.0.0.255 разрешает всю подсеть /24

permit any эквивалентно permit 0.0.0.0 255.255.255.255

Такие сокращения нужно читать как обычные wildcard-условия

Стандартные ACL бывают нумерованные и именованные

Нумерованные стандартные ACL обычно используют диапазоны 1–99 и 1300–1999

Именованные ACL легче читать и сопровождать

Пример: `ip access-list standard MGMT_ONLY` создает именованную стандартную ACL

Внутри `named` ACL можно добавлять строки `permit` и `deny` с `sequence numbers`

Для обучения лучше использовать имена, отражающие назначение фильтра

4. Стандартная ACL фильтрует только Source IP

Стандартная ACL не видит адрес назначения, TCP-порт или тип приложения

Она отвечает только на вопрос: откуда пришел трафик

Пример: `permit 192.168.99.0 0.0.0.255` разрешает источники из Management VLAN

Если нужно разрешить HTTP к серверу, а SSH запретить, нужна расширенная ACL

Стандартная ACL хороша для защиты VTY и простого ограничения источников

Стандартная ACL для защиты SSH-управления

Задача: разрешить SSH к роутеру только из
Management VLAN 192.168.99.0/24

`ip access-list standard MGMT_ONLY` открывает ACL

`permit 192.168.99.0 0.0.0.255` разрешает

администраторскую подсеть

`deny any log` можно добавить для явного запрета и
журналирования попыток

Важно не забыть: ACL должна быть применена к VTY
через `access-class`

Минимальная подготовка SSH перед access-class

hostname R1 задает имя устройства

ip domain-name company.test задает доменное имя
для генерации RSA-ключа

username admin privilege 15 secret StrongPassword
создает локального администратора

crypto key generate rsa modulus 2048 создает RSA-
ключи для SSH

ip ssh version 2 включает использование SSHv2

Если IOS не принимает modulus в одну строку, введите
crypto key generate rsa и укажите 2048 в диалоге

access-class защищает VTY, а не интерфейсный трафик

VTY (Virtual Teletype) — удаленные линии CLI-доступа
Telnet или SSH

Для VTY применяется команда access-class, а не ip
access-group

access-class MGMT_ONLY in ограничивает источники,
которым разрешен вход на VTY

transport input ssh запрещает Telnet и оставляет только
SSH

login local включает проверку по локальной базе
пользователей

Защищать нужно все существующие VTY-линии

На одних устройствах доступны только line vty 0 4

На многих Cisco IOS есть дополнительные line vty 5 15

Если защитить только 0 4, оставшиеся VTY могут остаться без access-class

Перед настройкой проверяют `show running-config | section line vty`

Одинаковые параметры SSH, login local и access-class применяют ко всем используемым диапазонам

Полный пример VTY-защиты через именованную ACL

```
ip access-list standard MGMT_ONLY; 10 permit  
192.168.99.0 0.0.0.255; 20 deny any log  
line vty 0 4; login local; transport input ssh; access-class  
MGMT_ONLY in  
line vty 5 15; login local; transport input ssh; access-class  
MGMT_ONLY in
```

SSH из Management VLAN должен проходить
SSH из пользовательской VLAN должен отклоняться

Нумерованная ACL тоже может защитить VTY

`access-list 10 permit 192.168.99.0 0.0.0.255` создает стандартную ACL номер 10

`line vty 0 4` открывает диапазон VTY-линий

`access-class 10 in` применяет список к входящим подключениям управления

`transport input ssh` оставляет только SSH

Именованный вариант удобнее сопровождать, но нумерованный важно уметь читать

Схема: доступ к VTY только из Management VLAN

Доступ к линиям управления (SSH) на маршрутизатор разрешён только из сети управления. Все остальные источники блокируются ACL.



Идея

ACL применяется к VTY-линиям (inbound).
Если IP-адрес источника не из Management VLAN —
подключение по SSH будет запрещено.

ACL: MGMT_ONLY (стандартная)

```
10 permit 192.168.99.0 0.0.0.255
```

! Разрешить только Management VLAN

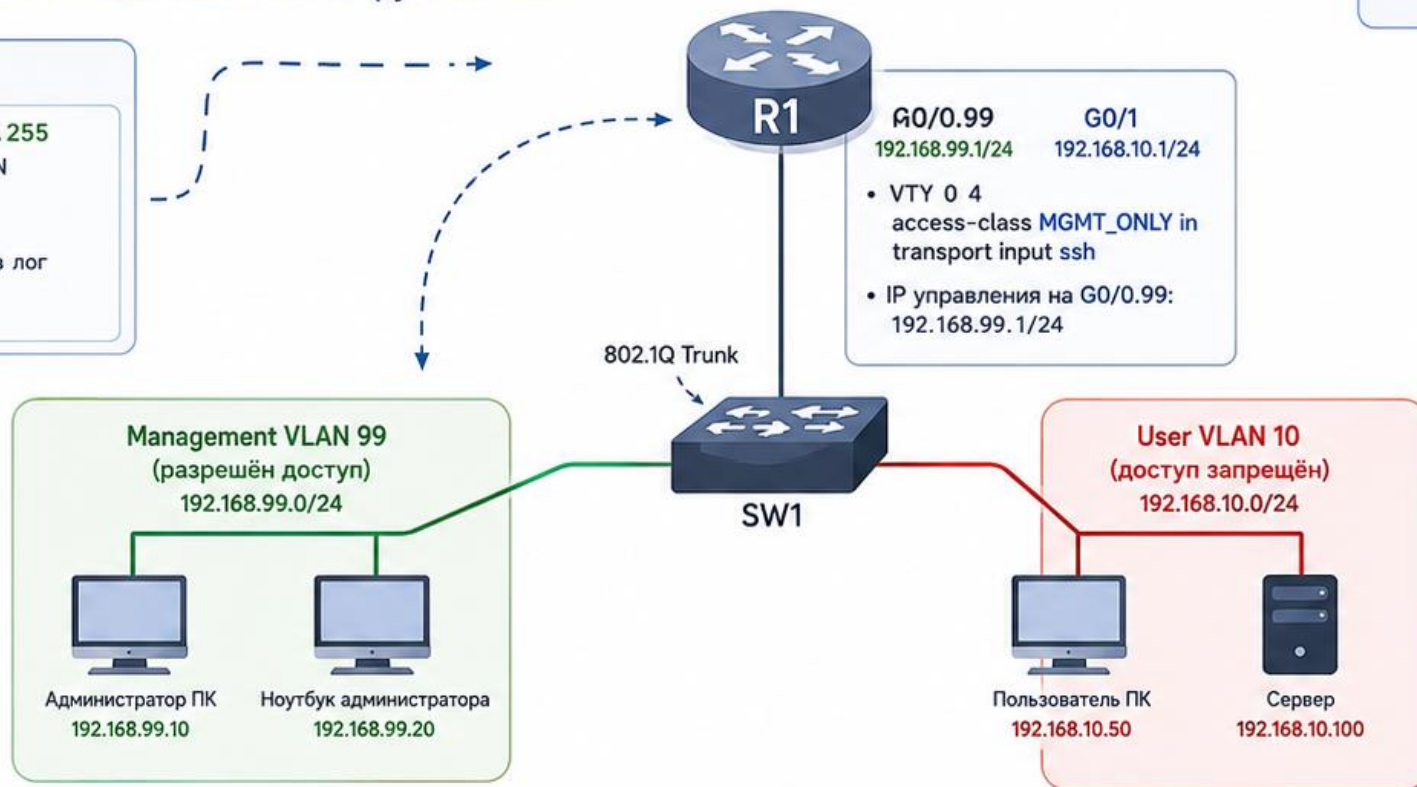
```
20 deny any log
```

! Запретить всё остальное и писать в лог

(implicit deny в конце списка)

Как это работает

- 1 Клиент из Management VLAN 99 открывает SSH сессии на адрес маршрутизатора (192.168.99.1).
- 2 Пакет приходит на VTY линии маршрутизатора.
- 3 ACL MGMT_ONLY проверяет IP источника.
- 4 Если источник из 192.168.99.0/24 — правило 10 permit, доступ разрешён.
- 5 Если источник любой другой — срабатывает правило 20 deny any, соединение отклоняется.
- 6 Если нет ни одного совпадения — срабатывает implicit deny.



Результат



Из Management VLAN (192.168.99.0/24)
→ SSH доступ разрешён

```
C:\> ssh 192.168.99.1
Password: *****
R1#
```



Из других сетей (не 192.168.99.0/24)
→ SSH доступ запрещён

```
C:\> ssh 192.168.10.1
ssh: connect to host 192.168.10.1
port 22: Connection timed out
```

Конфигурация (пример)

R1 — интерфейсы и подинтерфейс

```
interface g0/0
 no ip address
 no shutdown
!
interface g0/0.99
 encapsulation dot1Q 99
 ip address 192.168.99.1 255.255.255.0
!
interface g0/1
 ip address 192.168.10.1 255.255.255.0
 no shutdown
```

R1 — ACL и VTY

```
ip access-list standard MGMT_ONLY
10 permit 192.168.99.0 0.0.0.255
20 deny any log
!
line vty 0 4
 access-class MGMT_ONLY in
 transport input ssh
 login local
```

- Management VLAN 99 (разрешено)
- User VLAN 10 (запрещено)
- -> Применение ACL к VTY (in)



Маршрутизатор



Коммутатор



Клиент / Сервер

Проверка

```
R1# show access-lists MGMT_ONLY
R1# show line vty 0 4
R1# show run | section line vty
```

Счётчики совпадений ACL
показывают, сколько раз
сработало каждое правило.

Проверка стандартной ACL

`show access-lists` показывает правила и счетчики совпадений

`show ip access-lists` выводит IP ACL в удобном виде

`show running-config | section line vty` показывает примененный access-class

SSH из Management VLAN должен проходить

SSH из пользовательской VLAN должен быть отклонен

Счетчики matches помогают видеть реальный трафик

После попытки подключения счетчик у permit или deny должен увеличиться

Если счетчик не меняется, пакет не попадает под эту ACL

show access-lists и show ip access-lists показывают правила и matches

Возможные команды очистки зависят от IOS: clear access-list counters, clear access-list counters

MGMT_ONLY или clear ip access-list counters

В Packet Tracer часть команд очистки может отсутствовать

Если счетчик не меняется, проверяют путь трафика

ACL могла быть создана, но не применена

ACL применена не к тому интерфейсу или VTY-диапазону

Пакет совпал с более ранней ACE

Тестируется уже существующая SSH-сессия, а не новое подключение

Соединение блокируется раньше другой ACL или нет маршрута до устройства

Source IP может отличаться из-за NAT или jump host

5. Стандартные ACL обычно размещают ближе к получателю

Стандартная ACL знает только source IP и не знает конечное назначение трафика

Если поставить ее близко к источнику, можно случайно запретить этому источнику все направления
Размещение ближе к получателю ограничивает доступ именно к нужному ресурсу или сегменту

Это практическое правило, а не синтаксическое требование Cisco IOS

Для VTY правило реализуется особенно удобно: ACL применяется на линиях управления конкретного устройства

access-class in и ip access-group in имеют разный контекст

ip access-group ACL in на L3-интерфейсе проверяет пакет, входящий в маршрутизатор через интерфейс
ip access-group ACL out проверяет пакет, выходящий из маршрутизатора через интерфейс
access-class ACL in на VTY проверяет удаленного пользователя, который подключается к CLI
access-class ACL out ограничивает исходящие подключения из VTY-сессии и используется редко
Для защиты SSH нужен именно access-class MGMT_ONLY in

Интерфейсное применение ACL требует направления

`ip access-group ACL_NAME in` применяет ACL на входящих пакетах интерфейса

`ip access-group ACL_NAME out` применяет ACL на исходящих пакетах интерфейса

Направление выбирается относительно самого интерфейса маршрутизатора

Ошибочное направление — классическая причина, почему ACL не работает как ожидается

Для VTU используется `access-class`, поэтому `in` означает вход в линии управления

Стандартная ACL для базовой фильтрации подсети

Пример задачи: запретить VLAN 40 доступ к серверной VLAN 30

`ip access-list standard BLOCK_VLAN40` создает список
`deny 192.168.40.0 0.0.0.255` запрещает источники из
VLAN 40

`permit any` оставляет доступ другим источникам

`interface Vlan30; ip access-group BLOCK_VLAN40 out`
применяет ACL на выход к серверной VLAN

Почему ACL для VLAN 40 ставят на выход к VLAN 30

Путь: VLAN 40 → маршрутизатор → выход через Vlan30
→ серверная VLAN

ACL out на Vlan30 блокирует доступ VLAN 40 именно к серверной VLAN

Доступ VLAN 40 к другим направлениям при этом не блокируется

Стандартная ACL запрещает всю VLAN 40, но не умеет выбрать один сервер или порт

Для политики вида запретить только HTTP или ICMP нужна расширенная ACL

Типовые ошибки стандартных ACL

Забыли применить ACL к интерфейсу или VTY

Забыли permit для разрешенного трафика и сработал implicit deny

Неверно посчитали wildcard mask

Применили интерфейсную ACL не в том направлении

Для VTY использовали ip access-group вместо access-class

Разместили стандартную ACL слишком близко к источнику и заблокировали лишние направления

Диаграмма: где размещать стандартную ACL

Стандартная ACL проверяет только **Source IP**. Размещайте её ближе к **месту назначения**, чтобы не блокировать нужный трафик раньше времени.



Главное правило

Стандартную ACL ставим как можно ближе к получателю трафика, на интерфейсе, через который трафик входит в сеть получателя.

ПРАВИЛЬНО: ближе к получателю



Размещаем ACL на интерфейсе R2, который ведёт к сети назначения 10.10.10.0/24.

Так мы не блокируем другие потоки по пути.

Цель: защитить сервер 10.10.10.10



Стандартная ACL 10

```
10 deny 192.168.1.50 0.0.0.0
20 permit any
(implicit deny в конце списка)
```

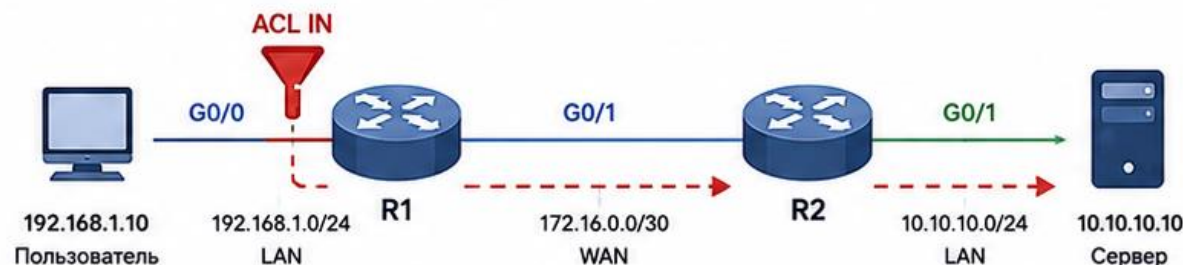
Как это работает

Фильтруем только те пакеты, которые уже дошли до сети назначения 10.10.10.0/24. Остальной трафик по пути (например, в интернет или другие сети) не затрагивается.

НЕПРАВИЛЬНО: слишком далеко от получателя



Если поставить ACL на R1 (на входе из LAN), мы заблокируем трафик к серверу и к другим сетям, куда источник может обращаться.



Стандартная ACL 10

```
10 deny 192.168.1.50 0.0.0.0
20 permit any
(implicit deny в конце списка)
```

Что произойдёт

Будут заблокированы все пакеты от 192.168.1.50 ко всем сетям за R1: не только к серверу 10.10.10.10, но и, например, в интернет или другие подсети.

Кратко о стандартной ACL



Проверяет только Source IP.



Подходит для фильтрации по источнику: блокируем ненужные подсети/адреса.



Размещаем ближе к получателю (destination).

Сравнение стандартной и расширенной ACL

Стандартная ACL	Расширенная ACL
Проверяет только Source IP	Проверяет Source IP, Destination IP, протокол, порты (L4)
Размещаем ближе к получателю	Размещаем ближе к источнику
Нумерованные: 1–99, 1300–1999 или именованные	Нумерованные: 100–199, 2000–2699 или именованные



Как выбрать место для ACL

- ✓ Определите, что является получателем трафика.
- ✓ Найдите интерфейс устройства, через который этот трафик входит в сеть получателя.
- ✓ Применяйте стандартную ACL на входящем направлении (in) этого интерфейса.
- ✓ Проверяйте счётчики: `show access-lists`.



Ошибка места размещения → нежелательная блокировка трафика или избыточная нагрузка на устройство.

Правила безопасной работы с ACL

Изменения ACL вступают в силу сразу после ввода команды

Перед применением записать цель ACL обычным языком

Сначала создать ACL и проверить строки `show access-lists`

Сначала добавить разрешающее правило для собственного адреса или Management VLAN

Применять ACL только при наличии консоли, out-of-band доступа или резервной SSH-сессии

Сохранить конфигурацию только после успешной

Безопасный порядок применения ACL на управление

Открыть вторую SSH-сессию или подготовить консольный доступ

Проверить локального пользователя, SSH и Management VLAN

Создать ACL и проверить ее содержимое

Применить access-class к VTY

Проверить новую SSH-сессию с разрешенного адреса

Проверить запрет с неразрешенного адреса и только потом закрывать резервное подключение

Sequence numbers помогают редактировать named ACL

В именованных ACL Cisco IOS показывает номера строк правил

Номер позволяет вставить новое правило между существующими строками

Пример: 10 permit 192.168.99.0 0.0.0.255, 20 deny any
log

Добавление исключения: 15 permit host
192.168.100.10

Удаление отдельной ACE: no 15

Это безопаснее, чем удалять и пересоздавать весь список во время удаленной работы

remark документирует назначение ACL прямо в конфигурации

remark добавляет комментарий внутри ACL

Пример: remark Разрешить SSH только из Management VLAN

Комментарии помогают читать ACL без отдельного документа

remark особенно полезен в длинных расширенных ACL

Хорошая практика документирования начинается уже со стандартных ACL

Перед ACL на управление нужен аварийный доступ

Ошибка в access-class может отрезать администратора от SSH

Перед применением ACL нужно иметь консольный доступ или резервную сессию

Сначала проверяют локального пользователя, SSH и Management VLAN

Затем применяют access-class и тестируют вход с разрешенного адреса

Только после проверки запрещенного адреса сохраняют конфигурацию

Документирование стандартной ACL

В документации указывают имя ACL и ее назначение

Фиксируют разрешенные source-сети и причины запретов

Отдельно указывают место применения: VTY, интерфейс, направление

Записывают команды проверки и ожидаемый результат

Указывают, какие VTY-диапазоны защищены: 0 4, 5 15 или другой набор

Итоги лекции

ACL фильтрует трафик только после применения к интерфейсу, VTY или другой функции устройства
ACL обрабатывается сверху вниз до первого совпадения ACE

В конце стандартной ACL есть `implicit deny any`, даже если он не написан явно

Стандартная ACL фильтрует только по Source IPv4 Address

VTY-доступ защищают через `access-class`, а интерфейсный трафик — через `ip access-group`

Счетчики `matches` помогают доказать, какое правило

Контрольные вопросы

Почему созданная ACL сама по себе еще не фильтрует трафик?

Чем ACL отличается от ACE?

Что такое `implicit deny` и где оно начинает действовать?

Чем стандартная ACL отличается от расширенной?

Почему стандартную ACL обычно размещают ближе к получателю?

Какая команда применяется для ограничения VTY-доступа?

Почему нужно защищать все VTY-диапазоны?